

Enterprise GRC Control Mapping

GDPR • ISO 27001 • ISO 42001 • DORA • NIS2

ENTERPRISE COMPLIANCE / GRC CASE STUDY

1. Executive Summary

The capstone brings the five preceding disciplines into one enterprise GRC operating model. The problem addressed is familiar in mature organisations: multiple compliance teams may test similar controls while maintaining separate evidence, ownership and remediation lists.

2. Business Context & Scope

The fictional enterprise operates corporate IT, cloud services, AI-enabled processes and regulated business activities. The model aims to reduce duplicated effort without pretending that different frameworks are interchangeable.

3. Governance & Accountability

Role	Accountability
Executive / Management	Sets risk appetite, approves material risk decisions and oversees remediation.
GRC / Risk / Compliance	Maintains methodology, challenges risk assessments, aggregates findings and reports to management.
Specialist Function	Provides subject-matter assurance for privacy, security, AI governance or ICT resilience, depending on the project.
Business / Process Owner	Owens the business risk and is accountable for remediation outcomes.
Control Owner	Operates the control and maintains evidence of operation.
Internal Audit	Provides independent assurance over governance and control effectiveness.

4. Assessment Methodology

The operating chain is Obligations → Risks → Common Controls → Framework Mapping → Evidence → Testing → Findings → Remediation → Management Reporting. A common control can support several frameworks, but each mapping retains its own rationale and accountability.

5. Risk Scoring

Likelihood (L) and Impact (I) are scored from 1–5. Inherent Risk = $L \times I$. Portfolio bands are 1–4 Low, 5–9 Moderate, 10–14 High and 15–25 Critical. Residual risk reflects the expected exposure after existing controls and treatment actions.

6. Risk Register

Risk ID	Risk Scenario	Likelihood (L)	Impact (I)	Inherent Risk	Risk Level	Primary Treatment	Residual Risk
GRC-01	Duplicated control ownership	4	4	16	Critical	Common-control ownership	6
GRC-02	Evidence cannot support assurance requests	3	4	12	High	Evidence index and standards	4
GRC-03	Regulatory change is not reflected in controls	3	5	15	Critical	Regulatory change process	6
GRC-04	AI governance is disconnected from the wider GRC model	3	4	12	High	Integrated AI, privacy and security governance	4

7. Gap Analysis & Findings

Finding	Area	Severity	Observation	Recommended Action
F-01	Control ownership	High	Framework teams duplicate activities because common-control accountability is fragmented.	Common control owner council.
F-02	Evidence reuse	High	Evidence is stored without consistent cross-framework metadata.	Metadata evidence-as-a-control operating model.
F-03	Regulatory change	High	Regulatory changes are manually tracked and impact assessment is inconsistent.	Quarterly regulatory-change review and impact assessment.

8. Remediation Roadmap

0–30 days: confirm owners, risk decisions and urgent containment.

31–90 days: strengthen priority controls, close evidence gaps and formalise exceptions.

91–180 days: introduce automation, recurring testing and management metrics.

181–365 days: embed continuous monitoring, reassessment and independent assurance.

9. KPI / KRI Management View

- Controls with accountable owner: 100%
- Evidence reused across applicable frameworks: >60%
- Overdue regulatory-change assessments: 0
- High-risk remediation completed on time: >90%

10. Evidence & Assurance

A production implementation would connect each control to an owner, evidence source, review period, testing result, exception status and remediation action. The public portfolio uses synthetic evidence only.

11. Management Conclusion

The case study shows the full management loop: understand the environment, identify material risks, evaluate controls, decide treatment, retain evidence and report residual exposure. The emphasis changes by framework so the portfolio demonstrates judgement rather than simple template reuse.

12. Portfolio Disclaimer

Synthetic professional case study for portfolio demonstration. It does not represent a real client engagement, audit opinion, certification or production implementation.